

ARROWNEX PVT. LTD.

Hack Start Pro - VAPT Internship Programme

VULNERABILITY ASSESSMENT & PENETRATION TESTING MONTH 1 LAB REPORT

Metasploitable 2 - Network Reconnaissance Assessment

Table 1: Document Information

Prepared by:	Sulav Adhikari
Programme:	Hack Start Pro - VAPT Internship
Organisation:	Arrownex Pvt. Ltd.
Target:	Metasploitable 2 VM - 192.168.63.128
Date:	22 April 2026
Classification:	CONFIDENTIAL

CONFIDENTIAL - FOR TRAINING PURPOSES ONLY

TABLE OF CONTENTS

1. Executive Summary	1
2. Scan Methodology	1
2.1 Target Environment	1
2.2 Nmap Scan Types Used	1
2.3 Combined Scan Command Used	2
3. Open Ports & Services Table	4
4. Service Analysis - High Risk Services	5
4.1 Port 21 - vsftpd 2.3.4 CVE-2011-2523	5
4.2 Port 23 - Telnet Plaintext Protocol (CWE-319)	6
4.3 Port 139/445 - Samba SMB 3.0.20 CVE-2007-2447	7
4.4 Port 3306 - MySQL 5.0.51a No-Password Root Access	8
4.5 Port 1524 - Ingres lock Intentional Root Backdoor	8
5. SMB Enumeration Results	9
5.1 OS & Server Information	9
5.2 Shares Found	10
5.3 Users Found via Null Session RID Cycling (35 Accounts)	11
5.4 Password Policy	12
6. Web Server Findings - Port 80	12
6.1 Niko Web Vulnerability Scan	12
6.2 Gobuster Directory Enumeration	15
7. Recommendations	16

TABLE OF FIGURES

Figure 1: Nmap SYN Stealth Scan Output	1
Figure 2: Nmap Full Combined Scan - open ports, versions, scripts	3
Figure 3: Nmap UDP Scan - Top 20 Ports.....	3
Figure 4: Nmap OS Detection - Linux 2.6.9–2.6.33 fingerprint	4
Figure 5: vsftpd 2.3.4 - Nmap ftp-anon script output on Port 21.....	5
Figure 6: Telnet Service - Connection Banner confirming Linux telnetd.....	6
Figure 7: Samba - smb-security-mode Script Output confirming disabled signing	7
Figure 8: MySQL - nmap mysql-info Script Output (Port 3306, no password)	8
Figure 9: Port 1524 Ingreslock - Netcat connection giving instant root shell	8
Figure 10: enum4linux - OS & Server Information (null session confirmed).....	9
Figure 11: enum4linux - Share Enumeration (tmp share publicly readable)	10
Figure 12: enum4linux - RID Cycling Output (35 accounts without authentication)	11
Figure 13: enum4linux - Password Policy (no lockout, no complexity).....	12
Figure 14: Nikto - Full Web Vulnerability Scan Output	13
Figure 15: phpMyAdmin - Publicly Accessible Database Admin Panel	13
Figure 16: phpinfo.php - Full PHP Configuration Exposure.....	14
Figure 17: Gobuster - Directory Enumeration Output.....	15

LIST OF TABLES

Table 1: Document Information	i
Table 2: Target Environment Details.....	1
Table 3: Nmap Scan Types Used.....	2
Table 4: Open Ports & Services with Risk Assessment	4
Table 5: Port 21 - vsftpd 2.3.4 Service Analysis	6
Table 6: Port 23 - Telnet Service Analysis.....	6
Table 7: Port 139/445 - Samba SMB Analysis	7
Table 8: Port 3306 - MySQL Analysis.....	8
Table 9: Port 1524 - Ingreslock Backdoor Analysis	9
Table 10: SMB OS & Server Information.....	9
Table 11: SMB Shares Found	11
Table 12: Users Found via Null Session (35 Accounts).....	11
Table 13: Password Policy.....	12
Table 14: Nikto Web Vulnerability Scan Results	14
Table 15: Gobuster Directory Enumeration Results	15
Table 16: Prioritised Recommendations	16

1. Executive Summary

A comprehensive network reconnaissance assessment was conducted on 22 April 2026 against a Metasploitable 2 virtual machine (IP: 192.168.63.128) as part of the Month 1 lab exercise for the Hack Start Pro VAPT Internship programme at Arrownex Pvt. Ltd. The assessment used industry-standard tools including Nmap, enum4linux, Nikto, and Gobuster to identify all open services, enumerate system users, and analyse the web attack surface.

The scan identified multiple critically vulnerable services, including an FTP server with a known remote root backdoor (CVE-2011-2523), an outdated Samba installation vulnerable to unauthenticated command injection (CVE-2007-2447), an exposed MySQL database with no root password, and a Telnet service transmitting all traffic in plaintext. Additionally, SMB null session enumeration revealed 35 user accounts without requiring any authentication, and web server analysis exposed a publicly accessible phpMyAdmin panel along with an outdated PHP/Apache stack with numerous misconfigurations.

The system presents an extremely high attack surface and would be fully compromised within minutes by any attacker with basic penetration testing skills. Immediate remediation is strongly recommended.

2. Scan Methodology

2.1 Target Environment

Table 2: Target Environment Details

Field	Detail
Attacker Machine	Kali Linux (kali@kali)
Target Machine	Metasploitable 2 - IP: 192.168.63.128
Network	VMware Host-Only Network (isolated lab environment)
Date & Time	22 April 2026, 20:45 - 20:52 NPT
Tools Used	Nmap 7.99, enum4linux v0.9.1, Nikto v2.6.0, Gobuster v3.8.2

2.2 Nmap Scan Types Used

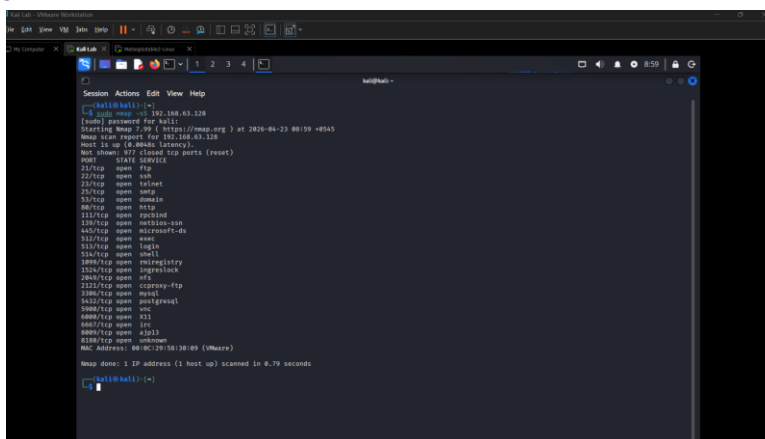


Figure 1: Nmap SYN Stealth Scan Output

Table 3: Nmap Scan Types Used

Scan Type	Flag	Purpose	Example Command
SYN Stealth	-sS	Fast, stealthy TCP scan. Does not complete the 3-way handshake. Less likely to trigger IDS/logging.	nmap -sS <IP>
Version Detect	-sV	Identifies exact service name and version on each open port.	nmap -sV <IP>
OS Detection	-O	Fingerprints the target OS via TCP/IP stack behaviour.	nmap -O <IP>
Default Scripts	-sC	Runs NSE default scripts: banner grabbing, SMB info, HTTP titles, FTP-anon, MySQL-info, etc.	nmap -sC <IP>
UDP Scan	-sU	Identifies open UDP services such as DNS (53), SNMP (161), NetBIOS (137).	nmap -sU --top-ports 20 <IP>

2.3 Combined Scan Command Used

sudo nmap -sS -sV -sC -O 192.168.63.128

sudo nmap -sU --top-ports 20 192.168.63.128

```

kali@kali:~$ sudo nmap -sS -sV -sC -O 192.168.63.128
Starting Nmap 7.91 (https://nmap.org) at 2020-04-23 08:59 -0500
Nmap scan report for 192.168.63.128
Host is up (0.0000000s latency).
Not shown: 655 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
111/tcp   open  rpcbind
135/tcp   open  msrpc
136/tcp   open  msrpc
137/tcp   open  netbios-ns
139/tcp   open  netbios-ssn
443/tcp   open  https
445/tcp   open  smb
593/tcp   open  msrpc
644/tcp   open  msrpc
688/tcp   open  msrpc
700/tcp   open  msrpc
701/tcp   open  msrpc
702/tcp   open  msrpc
703/tcp   open  msrpc
704/tcp   open  msrpc
705/tcp   open  msrpc
706/tcp   open  msrpc
707/tcp   open  msrpc
708/tcp   open  msrpc
709/tcp   open  msrpc
710/tcp   open  msrpc
711/tcp   open  msrpc
712/tcp   open  msrpc
713/tcp   open  msrpc
714/tcp   open  msrpc
715/tcp   open  msrpc
716/tcp   open  msrpc
717/tcp   open  msrpc
718/tcp   open  msrpc
719/tcp   open  msrpc
720/tcp   open  msrpc
721/tcp   open  msrpc
722/tcp   open  msrpc
723/tcp   open  msrpc
724/tcp   open  msrpc
725/tcp   open  msrpc
726/tcp   open  msrpc
727/tcp   open  msrpc
728/tcp   open  msrpc
729/tcp   open  msrpc
730/tcp   open  msrpc
731/tcp   open  msrpc
732/tcp   open  msrpc
733/tcp   open  msrpc
734/tcp   open  msrpc
735/tcp   open  msrpc
736/tcp   open  msrpc
737/tcp   open  msrpc
738/tcp   open  msrpc
739/tcp   open  msrpc
740/tcp   open  msrpc
741/tcp   open  msrpc
742/tcp   open  msrpc
743/tcp   open  msrpc
744/tcp   open  msrpc
745/tcp   open  msrpc
746/tcp   open  msrpc
747/tcp   open  msrpc
748/tcp   open  msrpc
749/tcp   open  msrpc
750/tcp   open  msrpc
751/tcp   open  msrpc
752/tcp   open  msrpc
753/tcp   open  msrpc
754/tcp   open  msrpc
755/tcp   open  msrpc
756/tcp   open  msrpc
757/tcp   open  msrpc
758/tcp   open  msrpc
759/tcp   open  msrpc
760/tcp   open  msrpc
761/tcp   open  msrpc
762/tcp   open  msrpc
763/tcp   open  msrpc
764/tcp   open  msrpc
765/tcp   open  msrpc
766/tcp   open  msrpc
767/tcp   open  msrpc
768/tcp   open  msrpc
769/tcp   open  msrpc
770/tcp   open  msrpc
771/tcp   open  msrpc
772/tcp   open  msrpc
773/tcp   open  msrpc
774/tcp   open  msrpc
775/tcp   open  msrpc
776/tcp   open  msrpc
777/tcp   open  msrpc
778/tcp   open  msrpc
779/tcp   open  msrpc
780/tcp   open  msrpc
781/tcp   open  msrpc
782/tcp   open  msrpc
783/tcp   open  msrpc
784/tcp   open  msrpc
785/tcp   open  msrpc
786/tcp   open  msrpc
787/tcp   open  msrpc
788/tcp   open  msrpc
789/tcp   open  msrpc
790/tcp   open  msrpc
791/tcp   open  msrpc
792/tcp   open  msrpc
793/tcp   open  msrpc
794/tcp   open  msrpc
795/tcp   open  msrpc
796/tcp   open  msrpc
797/tcp   open  msrpc
798/tcp   open  msrpc
799/tcp   open  msrpc
800/tcp   open  msrpc
801/tcp   open  msrpc
802/tcp   open  msrpc
803/tcp   open  msrpc
804/tcp   open  msrpc
805/tcp   open  msrpc
806/tcp   open  msrpc
807/tcp   open  msrpc
808/tcp   open  msrpc
809/tcp   open  msrpc
810/tcp   open  msrpc
811/tcp   open  msrpc
812/tcp   open  msrpc
813/tcp   open  msrpc
814/tcp   open  msrpc
815/tcp   open  msrpc
816/tcp   open  msrpc
817/tcp   open  msrpc
818/tcp   open  msrpc
819/tcp   open  msrpc
820/tcp   open  msrpc
821/tcp   open  msrpc
822/tcp   open  msrpc
823/tcp   open  msrpc
824/tcp   open  msrpc
825/tcp   open  msrpc
826/tcp   open  msrpc
827/tcp   open  msrpc
828/tcp   open  msrpc
829/tcp   open  msrpc
830/tcp   open  msrpc
831/tcp   open  msrpc
832/tcp   open  msrpc
833/tcp   open  msrpc
834/tcp   open  msrpc
835/tcp   open  msrpc
836/tcp   open  msrpc
837/tcp   open  msrpc
838/tcp   open  msrpc
839/tcp   open  msrpc
840/tcp   open  msrpc
841/tcp   open  msrpc
842/tcp   open  msrpc
843/tcp   open  msrpc
844/tcp   open  msrpc
845/tcp   open  msrpc
846/tcp   open  msrpc
847/tcp   open  msrpc
848/tcp   open  msrpc
849/tcp   open  msrpc
850/tcp   open  msrpc
851/tcp   open  msrpc
852/tcp   open  msrpc
853/tcp   open  msrpc
854/tcp   open  msrpc
855/tcp   open  msrpc
856/tcp   open  msrpc
857/tcp   open  msrpc
858/tcp   open  msrpc
859/tcp   open  msrpc
860/tcp   open  msrpc
861/tcp   open  msrpc
862/tcp   open  msrpc
863/tcp   open  msrpc
864/tcp   open  msrpc
865/tcp   open  msrpc
866/tcp   open  msrpc
867/tcp   open  msrpc
868/tcp   open  msrpc
869/tcp   open  msrpc
870/tcp   open  msrpc
871/tcp   open  msrpc
872/tcp   open  msrpc
873/tcp   open  msrpc
874/tcp   open  msrpc
875/tcp   open  msrpc
876/tcp   open  msrpc
877/tcp   open  msrpc
878/tcp   open  msrpc
879/tcp   open  msrpc
880/tcp   open  msrpc
881/tcp   open  msrpc
882/tcp   open  msrpc
883/tcp   open  msrpc
884/tcp   open  msrpc
885/tcp   open  msrpc
886/tcp   open  msrpc
887/tcp   open  msrpc
888/tcp   open  msrpc
889/tcp   open  msrpc
890/tcp   open  msrpc
891/tcp   open  msrpc
892/tcp   open  msrpc
893/tcp   open  msrpc
894/tcp   open  msrpc
895/tcp   open  msrpc
896/tcp   open  msrpc
897/tcp   open  msrpc
898/tcp   open  msrpc
899/tcp   open  msrpc
900/tcp   open  msrpc
901/tcp   open  msrpc
902/tcp   open  msrpc
903/tcp   open  msrpc
904/tcp   open  msrpc
905/tcp   open  msrpc
906/tcp   open  msrpc
907/tcp   open  msrpc
908/tcp   open  msrpc
909/tcp   open  msrpc
910/tcp   open  msrpc
911/tcp   open  msrpc
912/tcp   open  msrpc
913/tcp   open  msrpc
914/tcp   open  msrpc
915/tcp   open  msrpc
916/tcp   open  msrpc
917/tcp   open  msrpc
918/tcp   open  msrpc
919/tcp   open  msrpc
920/tcp   open  msrpc
921/tcp   open  msrpc
922/tcp   open  msrpc
923/tcp   open  msrpc
924/tcp   open  msrpc
925/tcp   open  msrpc
926/tcp   open  msrpc
927/tcp   open  msrpc
928/tcp   open  msrpc
929/tcp   open  msrpc
930/tcp   open  msrpc
931/tcp   open  msrpc
932/tcp   open  msrpc
933/tcp   open  msrpc
934/tcp   open  msrpc
935/tcp   open  msrpc
936/tcp   open  msrpc
937/tcp   open  msrpc
938/tcp   open  msrpc
939/tcp   open  msrpc
940/tcp   open  msrpc
941/tcp   open  msrpc
942/tcp   open  msrpc
943/tcp   open  msrpc
944/tcp   open  msrpc
945/tcp   open  msrpc
946/tcp   open  msrpc
947/tcp   open  msrpc
948/tcp   open  msrpc
949/tcp   open  msrpc
950/tcp   open  msrpc
951/tcp   open  msrpc
952/tcp   open  msrpc
953/tcp   open  msrpc
954/tcp   open  msrpc
955/tcp   open  msrpc
956/tcp   open  msrpc
957/tcp   open  msrpc
958/tcp   open  msrpc
959/tcp   open  msrpc
960/tcp   open  msrpc
961/tcp   open  msrpc
962/tcp   open  msrpc
963/tcp   open  msrpc
964/tcp   open  msrpc
965/tcp   open  msrpc
966/tcp   open  msrpc
967/tcp   open  msrpc
968/tcp   open  msrpc
969/tcp   open  msrpc
970/tcp   open  msrpc
971/tcp   open  msrpc
972/tcp   open  msrpc
973/tcp   open  msrpc
974/tcp   open  msrpc
975/tcp   open  msrpc
976/tcp   open  msrpc
977/tcp   open  msrpc
978/tcp   open  msrpc
979/tcp   open  msrpc
980/tcp   open  msrpc
981/tcp   open  msrpc
982/tcp   open  msrpc
983/tcp   open  msrpc
984/tcp   open  msrpc
985/tcp   open  msrpc
986/tcp   open  msrpc
987/tcp   open  msrpc
988/tcp   open  msrpc
989/tcp   open  msrpc
990/tcp   open  msrpc
991/tcp   open  msrpc
992/tcp   open  msrpc
993/tcp   open  msrpc
994/tcp   open  msrpc
995/tcp   open  msrpc
996/tcp   open  msrpc
997/tcp   open  msrpc
998/tcp   open  msrpc
999/tcp   open  msrpc
1000/tcp  open  msrpc

```

```

kali@kali:~$ sudo nmap -sU --top-ports 20 192.168.63.128
Starting Nmap 7.91 (https://nmap.org) at 2020-04-23 09:01 -0500
Nmap scan report for 192.168.63.128
Host is up (0.0000000s latency).
Not shown: 655 closed udp ports (no response)
PORT      STATE SERVICE
53/udp    open  dns
80/udp    open  http
111/udp   open  rpcbind
135/udp   open  msrpc
136/udp   open  msrpc
137/udp   open  netbios-ns
139/udp   open  netbios-ssn
443/udp   open  https
445/udp   open  smb
593/udp   open  msrpc
644/udp   open  msrpc
688/udp   open  msrpc
700/udp   open  msrpc
701/udp   open  msrpc
702/udp   open  msrpc
703/udp   open  msrpc
704/udp   open  msrpc
705/udp   open  msrpc
706/udp   open  msrpc
707/udp   open  msrpc
708/udp   open  msrpc
709/udp   open  msrpc
710/udp   open  msrpc
711/udp   open  msrpc
712/udp   open  msrpc
713/udp   open  msrpc
714/udp   open  msrpc
715/udp   open  msrpc
716/udp   open  msrpc
717/udp   open  msrpc
718/udp   open  msrpc
719/udp   open  msrpc
720/udp   open  msrpc
721/udp   open  msrpc
722/udp   open  msrpc
723/udp   open  msrpc
724/udp   open  msrpc
725/udp   open  msrpc
726/udp   open  msrpc
727/udp   open  msrpc
728/udp   open  msrpc
729/udp   open  msrpc
730/udp   open  msrpc
731/udp   open  msrpc
732/udp   open  msrpc
733/udp   open  msrpc
734/udp   open  msrpc
735/udp   open  msrpc
736/udp   open  msrpc
737/udp   open  msrpc
738/udp   open  msrpc
739/udp   open  msrpc
740/udp   open  msrpc
741/udp   open  msrpc
742/udp   open  msrpc
743/udp   open  msrpc
744/udp   open  msrpc
745/udp   open  msrpc
746/udp   open  msrpc
747/udp   open  msrpc
748/udp   open  msrpc
749/udp   open  msrpc
750/udp   open  msrpc
751/udp   open  msrpc
752/udp   open  msrpc
753/udp   open  msrpc
754/udp   open  msrpc
755/udp   open  msrpc
756/udp   open  msrpc
757/udp   open  msrpc
758/udp   open  msrpc
759/udp   open  msrpc
760/udp   open  msrpc
761/udp   open  msrpc
762/udp   open  msrpc
763/udp   open  msrpc
764/udp   open  msrpc
765/udp   open  msrpc
766/udp   open  msrpc
767/udp   open  msrpc
768/udp   open  msrpc
769/udp   open  msrpc
770/udp   open  msrpc
771/udp   open  msrpc
772/udp   open  msrpc
773/udp   open  msrpc
774/udp   open  msrpc
775/udp   open  msrpc
776/udp   open  msrpc
777/udp   open  msrpc
778/udp   open  msrpc
779/udp   open  msrpc
780/udp   open  msrpc
781/udp   open  msrpc
782/udp   open  msrpc
783/udp   open  msrpc
784/udp   open  msrpc
785/udp   open  msrpc
786/udp   open  msrpc
787/udp   open  msrpc
788/udp   open  msrpc
789/udp   open  msrpc
790/udp   open  msrpc
791/udp   open  msrpc
792/udp   open  msrpc
793/udp   open  msrpc
794/udp   open  msrpc
795/udp   open  msrpc
796/udp   open  msrpc
797/udp   open  msrpc
798/udp   open  msrpc
799/udp   open  msrpc
800/udp   open  msrpc
801/udp   open  msrpc
802/udp   open  msrpc
803/udp   open  msrpc
804/udp   open  msrpc
805/udp   open  msrpc
806/udp   open  msrpc
807/udp   open  msrpc
808/udp   open  msrpc
809/udp   open  msrpc
810/udp   open  msrpc
811/udp   open  msrpc
812/udp   open  msrpc
813/udp   open  msrpc
814/udp   open  msrpc
815/udp   open  msrpc
816/udp   open  msrpc
817/udp   open  msrpc
818/udp   open  msrpc
819/udp   open  msrpc
820/udp   open  msrpc
821/udp   open  msrpc
822/udp   open  msrpc
823/udp   open  msrpc
824/udp   open  msrpc
825/udp   open  msrpc
826/udp   open  msrpc
827/udp   open  msrpc
828/udp   open  msrpc
829/udp   open  msrpc
830/udp   open  msrpc
831/udp   open  msrpc
832/udp   open  msrpc
833/udp   open  msrpc
834/udp   open  msrpc
835/udp   open  msrpc
836/udp   open  msrpc
837/udp   open  msrpc
838/udp   open  msrpc
839/udp   open  msrpc
840/udp   open  msrpc
841/udp   open  msrpc
842/udp   open  msrpc
843/udp   open  msrpc
844/udp   open  msrpc
845/udp   open  msrpc
846/udp   open  msrpc
847/udp   open  msrpc
848/udp   open  msrpc
849/udp   open  msrpc
850/udp   open  msrpc
851/udp   open  msrpc
852/udp   open  msrpc
853/udp   open  msrpc
854/udp   open  msrpc
855/udp   open  msrpc
856/udp   open  msrpc
857/udp   open  msrpc
858/udp   open  msrpc
859/udp   open  msrpc
860/udp   open  msrpc
861/udp   open  msrpc
862/udp   open  msrpc
863/udp   open  msrpc
864/udp   open  msrpc
865/udp   open  msrpc
866/udp   open  msrpc
867/udp   open  msrpc
868/udp   open  msrpc
869/udp   open  msrpc
870/udp   open  msrpc
871/udp   open  msrpc
872/udp   open  msrpc
873/udp   open  msrpc
874/udp   open  msrpc
875/udp   open  msrpc
876/udp   open  msrpc
877/udp   open  msrpc
878/udp   open  msrpc
879/udp   open  msrpc
880/udp   open  msrpc
881/udp   open  msrpc
882/udp   open  msrpc
883/udp   open  msrpc
884/udp   open  msrpc
885/udp   open  msrpc
886/udp   open  msrpc
887/udp   open  msrpc
888/udp   open  msrpc
889/udp   open  msrpc
890/udp   open  msrpc
891/udp   open  msrpc
892/udp   open  msrpc
893/udp   open  msrpc
894/udp   open  msrpc
895/udp   open  msrpc
896/udp   open  msrpc
897/udp   open  msrpc
898/udp   open  msrpc
899/udp   open  msrpc
900/udp   open  msrpc
901/udp   open  msrpc
902/udp   open  msrpc
903/udp   open  msrpc
904/udp   open  msrpc
905/udp   open  msrpc
906/udp   open  msrpc
907/udp   open  msrpc
908/udp   open  msrpc
909/udp   open  msrpc
910/udp   open  msrpc
911/udp   open  msrpc
912/udp   open  msrpc
913/udp   open  msrpc
914/udp   open  msrpc
915/udp   open  msrpc
916/udp   open  msrpc
917/udp   open  msrpc
918/udp   open  msrpc
919/udp   open  msrpc
920/udp   open  msrpc
921/udp   open  msrpc
922/udp   open  msrpc
923/udp   open  msrpc
924/udp   open  msrpc
925/udp   open  msrpc
926/udp   open  msrpc
927/udp   open  msrpc
928/udp   open  msrpc
929/udp   open  msrpc
930/udp   open  msrpc
931/udp   open  msrpc
932/udp   open  msrpc
933/udp   open  msrpc
934/udp   open  msrpc
935/udp   open  msrpc
936/udp   open  msrpc
937/udp   open  msrpc
938/udp   open  msrpc
939/udp   open  msrpc
940/udp   open  msrpc
941/udp   open  msrpc
942/udp   open  msrpc
943/udp   open  msrpc
944/udp   open  msrpc
945/udp   open  msrpc
946/udp   open  msrpc
947/udp   open  msrpc
948/udp   open  msrpc
949/udp   open  msrpc
950/udp   open  msrpc
951/udp   open  msrpc
952/udp   open  msrpc
953/udp   open  msrpc
954/udp   open  msrpc
955/udp   open  msrpc
956/udp   open  msrpc
957/udp   open  msrpc
958/udp   open  msrpc
959/udp   open  msrpc
960/udp   open  msrpc
961/udp   open  msrpc
962/udp   open  msrpc
963/udp   open  msrpc
964/udp   open  msrpc
965/udp   open  msrpc
966/udp   open  msrpc
967/udp   open  msrpc
968/udp   open  msrpc
969/udp   open  msrpc
970/udp   open  msrpc
971/udp   open  msrpc
972/udp   open  msrpc
973/udp   open  msrpc
974/udp   open  msrpc
975/udp   open  msrpc
976/udp   open  msrpc
977/udp   open  msrpc
978/udp   open  msrpc
979/udp   open  msrpc
980/udp   open  msrpc
981/udp   open  msrpc
982/udp   open  msrpc
983/udp   open  msrpc
984/udp   open  msrpc
985/udp   open  msrpc
986/udp   open  msrpc
987/udp   open  msrpc
988/udp   open  msrpc
989/udp   open  msrpc
990/udp   open  msrpc
991/udp   open  msrpc
992/udp   open  msrpc
993/udp   open  msrpc
994/udp   open  msrpc
995/udp   open  msrpc
996/udp   open  msrpc
997/udp   open  msrpc
998/udp   open  msrpc
999/udp   open  msrpc
1000/udp  open  msrpc

```

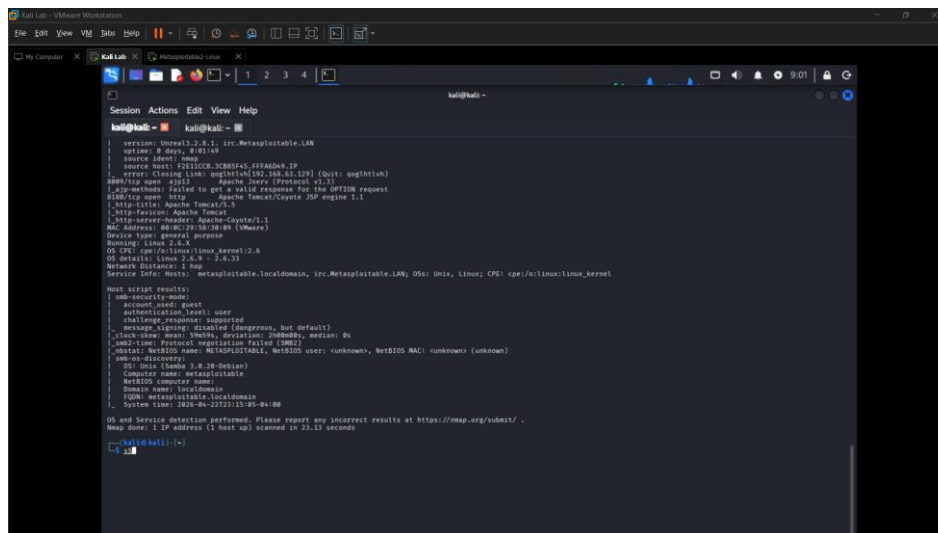


Figure 2: Nmap Full Combined Scan - open ports, versions, scripts

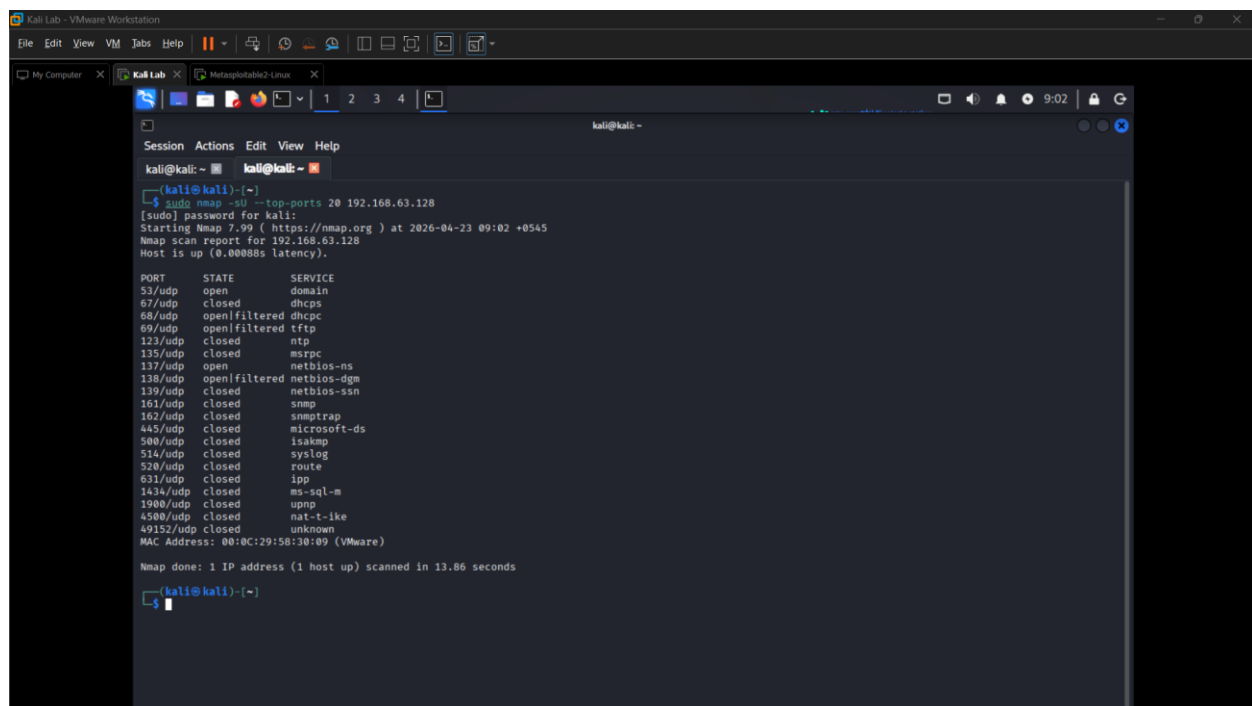


Figure 3: Nmap UDP Scan - Top 20 Ports

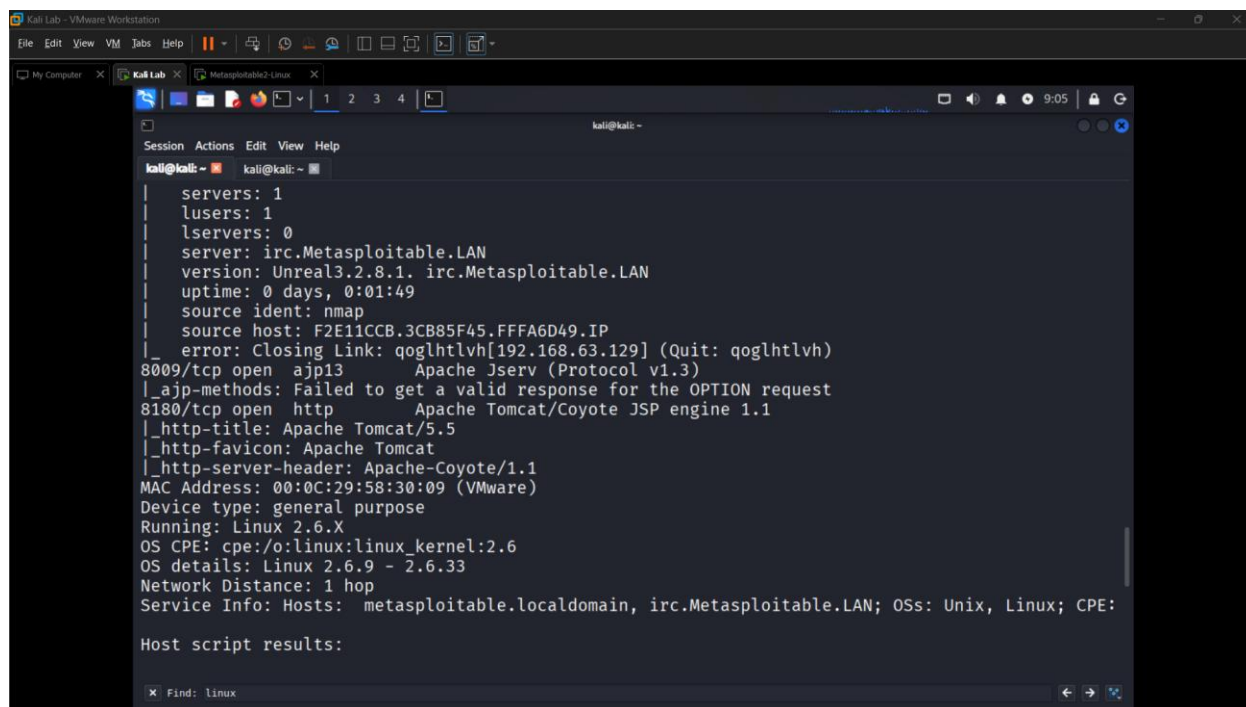


Figure 4: Nmap OS Detection - Linux 2.6.9–2.6.33 fingerprint

The combined scan was run with sudo to enable raw socket access for SYN stealth scanning and OS fingerprinting. The -sC flag automatically ran NSE default scripts including smb-os-discovery, ftp-anon, ssh-hostkey, vnc-info, and mysql-info, providing rich banner information. The UDP scan confirmed DNS (53/udp) and NetBIOS-NS (137/udp) are open.

3. Open Ports & Services Table

The following table lists all open ports discovered during the assessment against 192.168.63.128. Risk levels are assigned based on known CVEs, default credentials, plaintext protocols, and exposure severity.

Table 4: Open Ports & Services with Risk Assessment

Port	State	Service	Version / Banner	Risk
21/tcp	Open	FTP	vsftpd 2.3.4	HIGH
22/tcp	Open	SSH	OpenSSH 4.7p1 Debian 8ubuntu1	MEDIUM
23/tcp	Open	Telnet	Linux telnetd	HIGH
25/tcp	Open	SMTP	Postfix smtpd (SSLv2 enabled)	MEDIUM
53/tcp	Open	DNS	ISC BIND 9.4.2	MEDIUM
80/tcp	Open	HTTP	Apache httpd 2.2.8 (Ubuntu) DAV/2	HIGH
111/tcp	Open	RPC	rpcbind 2 (RPC #100000) - exposes NFS	LOW
139/tcp	Open	NetBIOS-SSN	Samba smbd 3.X - 4.X	HIGH
445/tcp	Open	SMB	Samba smbd 3.0.20-Debian	HIGH

Port	State	Service	Version / Banner	Risk
512/tcp	Open	exec (rexec)	netkit-rsh rexecd	HIGH
513/tcp	Open	login (rlogin)	OpenBSD or Solaris rlogind	HIGH
514/tcp	Open	shell (rsh)	Netkit rshd (tcpwrapped)	HIGH
1099/tcp	Open	Java RMI	GNU Classpath gmmiregistry	MEDIUM
1524/tcp	Open	Bindshell	Metasploitable root shell (intentional backdoor)	HIGH
2049/tcp	Open	NFS	NFS 2-4 (RPC #100003)	MEDIUM
2121/tcp	Open	FTP	ProFTPD 1.3.1	HIGH
3306/tcp	Open	MySQL	MySQL 5.0.51a-3ubuntu5 (no password)	HIGH
5432/tcp	Open	PostgreSQL	PostgreSQL DB 8.3.0 - 8.3.7	MEDIUM
5900/tcp	Open	VNC	VNC (protocol 3.3) - Auth type 2	HIGH
6000/tcp	Open	X11	X11 (access denied)	MEDIUM
6667/tcp	Open	IRC	UnrealIRCd Unreal3.2.8.1	HIGH
8009/tcp	Open	AJP	Apache Jserv Protocol v1.3	MEDIUM
8180/tcp	Open	HTTP (Tomcat)	Apache Tomcat/Coyote JSP 1.1 / Tomcat 5.5	HIGH

UDP Scan Results (Top 20 Ports): 53/udp open (domain), 137/udp open (netbios-ns), 68/udp open|filtered (dhcpc), 161/udp open|filtered (snmp). OS Detected: Linux 2.6.9–2.6.33. NetBIOS Name: METASPLOITABLE.

4. Service Analysis - High Risk Services

The following sections analyse each HIGH risk service identified during the scan: what it is, why it is dangerous, the associated CVE or attack method, and the potential impact.

4.1 Port 21 - vsftpd 2.3.4 | CVE-2011-2523

```

kali@kali: ~
└─$ nmap -sT 192.168.63.128
Nmap scan report for 192.168.63.128
Host is up (0.00084s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
|_ftp-syst:
|_STAT:
|_FTP server status:
|_Connected to 192.168.63.129
|_Logged in as ftp
|_TYPE: ASCII
|_No session bandwidth limit
|_Session timeout in seconds is 300
|_Control connection is plain text
|_Data connections will be plain text
|_vsFTPd 2.3.4 - secure, fast, stable
|_End of status
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
|_ssh-hostkey:
|_1024 60:0f:cf:e1:c0:5f:6a:74:d6:90:24:fa:c4:d5:6c:cd (DSA)
|_2048 56:56:24:0f:21:1d:de:a7:2b:ae:61:b1:24:3d:e8:f3 (RSA)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd

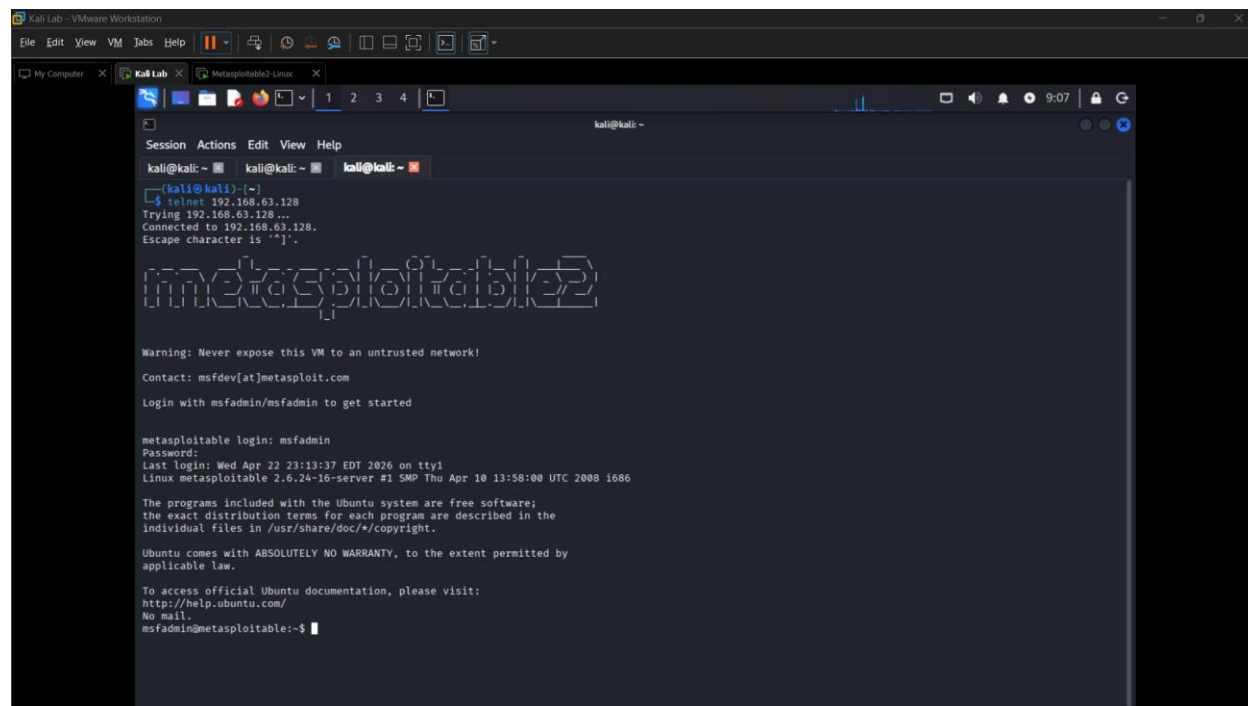
```

Figure 5: vsftpd 2.3.4 - Nmap ftp-anon script output on Port 21

Table 5: Port 21 - vsftpd 2.3.4 Service Analysis

What it is	vsftpd (Very Secure FTP Daemon) is an FTP server. Version 2.3.4 contains a deliberately introduced malicious backdoor pushed into the source code repository in 2011.
Why it is risky	If a username containing ":-)" is sent during login, vsftpd opens a root shell listener on TCP port 6200 with no authentication required. Nmap ftp-anon also shows anonymous login is allowed.
CVE	CVE-2011-2523 - CVSS Score: 10.0 (Critical)
Exploit Method	Metasploit: use exploit/unix/ftp/vsftpd_234_backdoor - provides immediate root shell with no credentials required.
Impact	Full root-level system compromise with zero authentication.

4.2 Port 23 - Telnet | Plaintext Protocol (CWE-319)

**Figure 6: Telnet Service - Connection Banner confirming Linux telnetd****Table 6: Port 23 - Telnet Service Analysis**

What it is	Telnet is a legacy remote administration protocol providing a command-line interface. Nmap confirmed it is running Linux telnetd.
Why it is risky	All data - including usernames, passwords, and commands - is transmitted in completely plain text. Any attacker performing a network sniff with Wireshark can capture credentials instantly.
CVE / Weakness	CWE-319: Cleartext Transmission of Sensitive Information. No specific CVE - the protocol itself is inherently insecure.
Exploit Method	Credential sniffing via Wireshark or Ettercap on the network segment. Direct login attempt: telnet 192.168.63.128

Impact	Full credential exposure and session hijacking for any user logging in via Telnet.
--------	--

4.3 Port 139/445 - Samba SMB 3.0.20 | CVE-2007-2447

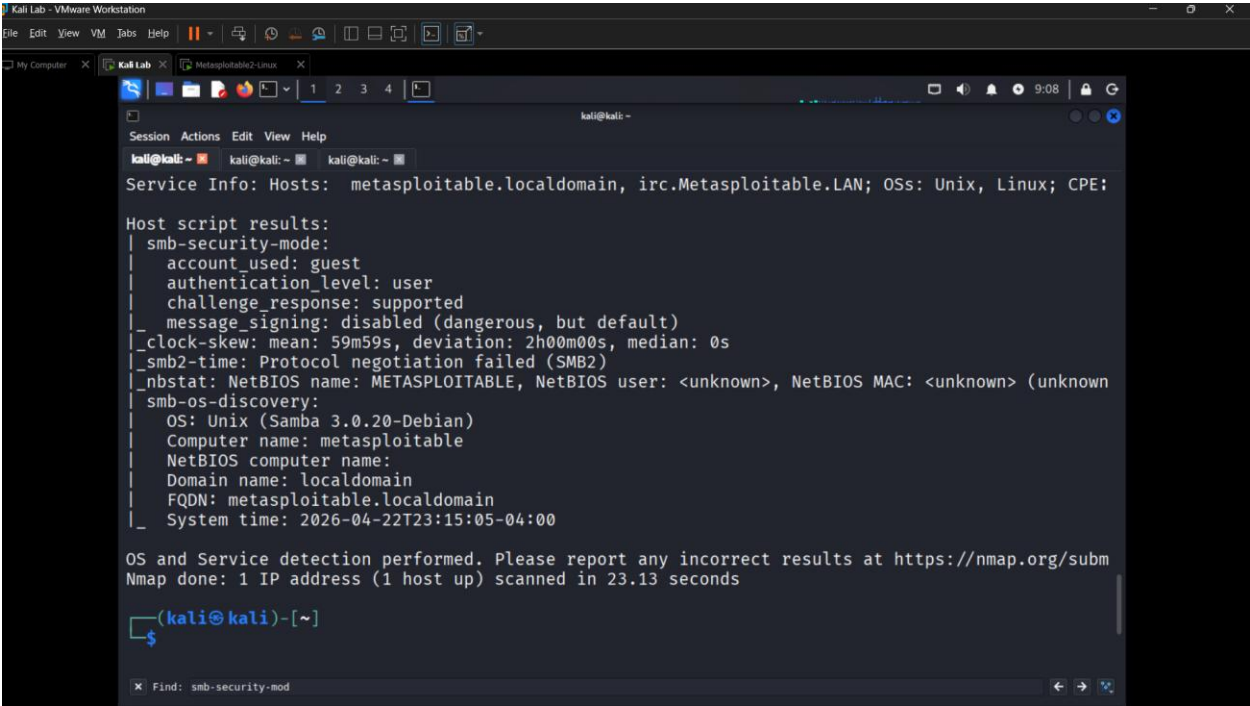


Figure 7: Samba - smb-security-mode Script Output confirming disabled signing

Table 7: Port 139/445 - Samba SMB Analysis

What it is	Samba is an open-source implementation of SMB/CIFS for file sharing. Nmap confirmed Samba smbd 3.0.20-Debian. SMB message signing is disabled (dangerous, but default).
Why it is risky	Samba 3.0.20 contains a command injection vulnerability in the username map script. Shell metacharacters in the username field execute arbitrary commands as root.
CVE	CVE-2007-2447 - CVSS Score: 9.3 (Critical). Affects Samba 3.0.0 to 3.0.25rc3.
Exploit Method	Metasploit: use exploit/multi/samba/usermap_script - no credentials required. Remote unauthenticated root shell.
Impact	Remote unauthenticated root shell on the target system.

4.4 Port 3306 - MySQL 5.0.51a | No-Password Root Access

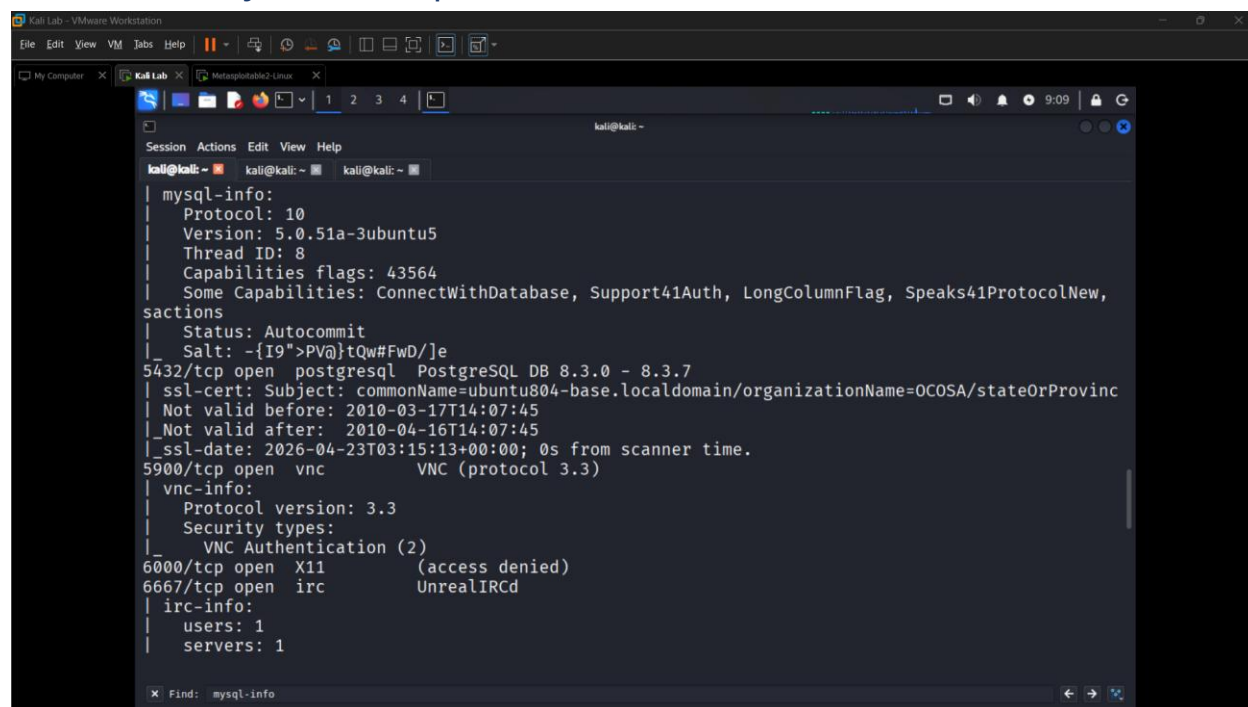


Figure 8: MySQL - nmap mysql-info Script Output (Port 3306, no password)

Table 8: Port 3306 - MySQL Analysis

What it is	MySQL is an open-source relational database management system. Nmap confirmed MySQL 5.0.51a-3ubuntu5 with full capabilities flags.
Why it is risky	The MySQL root account has no password. Any attacker can login directly: <code>mysql -h 192.168.63.128 -u root</code> - gaining full access to all databases.
CVE / Weakness	CVE-2012-5613 (MySQL UDF privilege escalation). CWE-798: Use of Hard-coded Credentials.
Exploit Method	Direct unauthenticated login: <code>mysql -h 192.168.63.128 -u root</code> (no password required at the prompt).
Impact	Full database access, data exfiltration, and potential OS command execution via MySQL User Defined Functions (UDF).

4.5 Port 1524 - Ingres lock | Intentional Root Backdoor

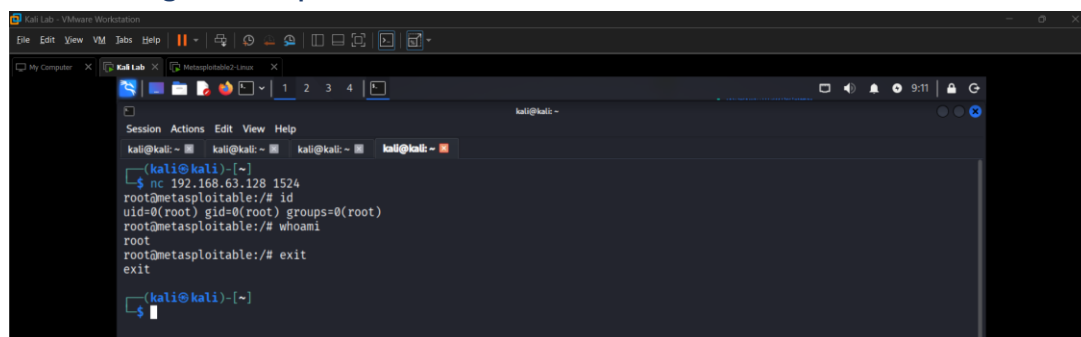


Figure 9: Port 1524 Ingreslock - Netcat connection giving instant root shell

Table 9: Port 1524 - Ingreslock Backdoor Analysis

What it is	Port 1524 is an intentionally open backdoor on Metasploitable 2. Nmap reports it as: bindshell - Metasploitable root shell.
Why it is risky	Connecting to this port with a basic Netcat command drops the attacker directly into a root shell with zero authentication required.
CVE / Weakness	No CVE - intentional backdoor. CWE-912: Hidden Functionality.
Exploit Method	nc 192.168.63.128 1524 - immediate root shell, no credentials.
Impact	Instant full root access to the system by any unauthenticated user on the network.

5. SMB Enumeration Results

Command: `enum4linux -a 192.168.63.128`

5.1 OS & Server Information

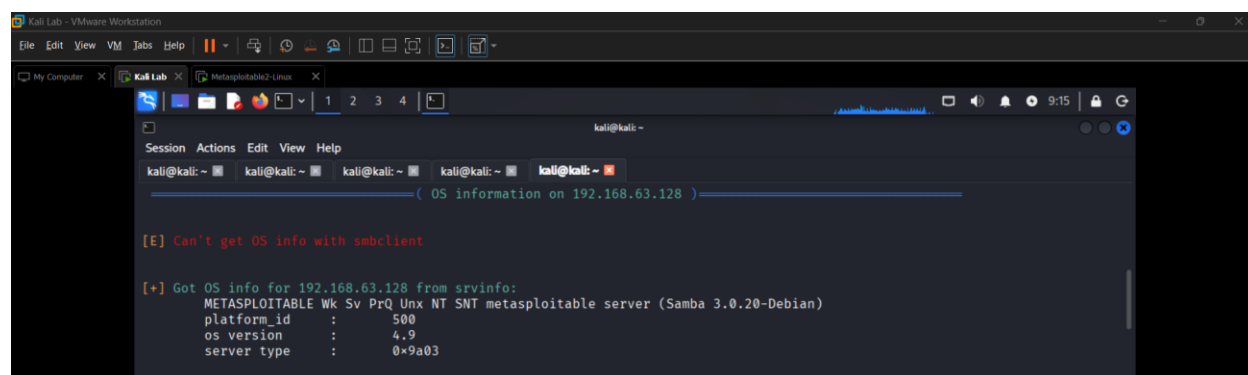
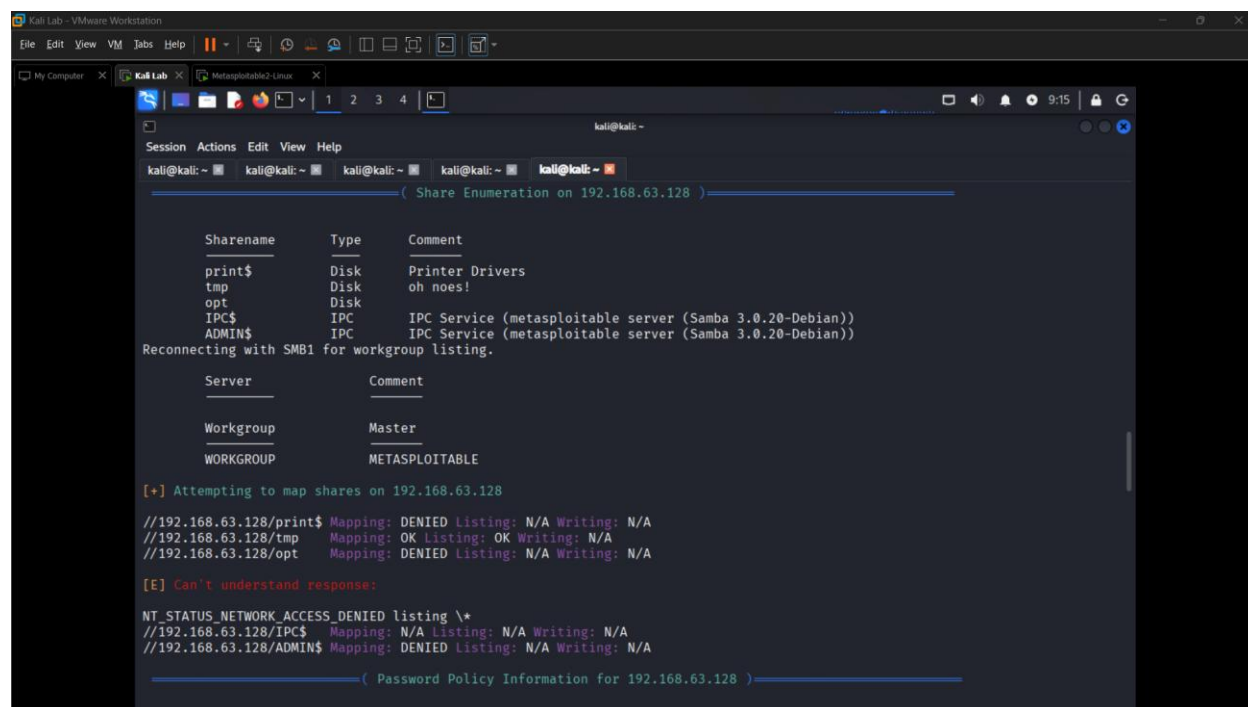


Figure 10: enum4linux - OS & Server Information (null session confirmed)

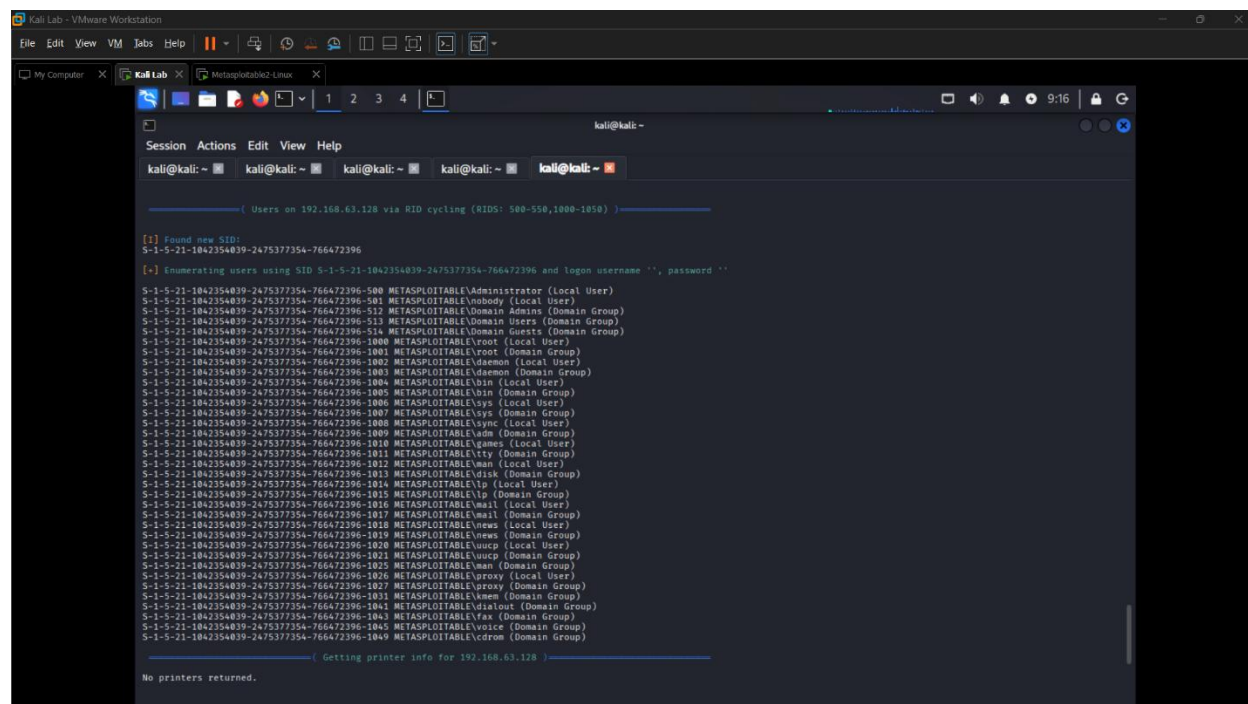
Table 10: SMB OS & Server Information

Field	Value
Server Name	METASPLOITABLE
OS / Platform	Samba 3.0.20-Debian OS Version: 4.9 Platform ID: 500 Server Type: 0x9a03
Domain / Workgroup	WORKGROUP
FQDN	metasploitable.localdomain
Null Session	ALLOWED - Server accepts login with empty username and empty password
SMB Signing	DISABLED - message_signing: disabled (dangerous, but default)

5.2 Shares Found



```
kali@kali: ~  
Session Actions Edit View Help  
kali@kali: ~ kali@kali: ~ kali@kali: ~ kali@kali: ~ kali@kali: ~  
----- ( Share Enumeration on 192.168.63.128 ) -----  
  
Sharename      Type      Comment  
-----  
print$         Disk      Printer Drivers  
tmp            Disk      oh noes!  
opt            Disk  
IPC$           IPC       IPC Service (metasploitable server (Samba 3.0.20-Debian))  
ADMIN$         IPC       IPC Service (metasploitable server (Samba 3.0.20-Debian))  
Reconnecting with SMB1 for workgroup listing.  
  
Server          Comment  
-----  
Workgroup        Master  
WORKGROUP        METASPLOITABLE  
  
[+] Attempting to map shares on 192.168.63.128  
  
//192.168.63.128/print$ Mapping: DENIED Listing: N/A Writing: N/A  
//192.168.63.128/tmp Mapping: OK Listing: OK Writing: N/A  
//192.168.63.128/opt Mapping: DENIED Listing: N/A Writing: N/A  
  
[E] Can't understand response:  
  
NT_STATUS_NETWORK_ACCESS_DENIED listing \*  
//192.168.63.128/IPC$ Mapping: N/A Listing: N/A Writing: N/A  
//192.168.63.128/ADMIN$ Mapping: DENIED Listing: N/A Writing: N/A  
  
----- ( Password Policy Information for 192.168.63.128 ) -----
```



```
kali@kali: ~  
Session Actions Edit View Help  
kali@kali: ~ kali@kali: ~ kali@kali: ~ kali@kali: ~ kali@kali: ~  
----- ( Users on 192.168.63.128 via RID cycling (RIDS: 500-550,1000-1050) ) -----  
  
[+] Found new SID:  
S-1-5-21-1042354039-2475377354-766472396  
[+] Enumerating users using SID S-1-5-21-1042354039-2475377354-766472396 and login username '', password ''  
  
S-1-5-21-1042354039-2475377354-766472396-500 METASPLOITABLE\Administrator (Local User)  
S-1-5-21-1042354039-2475377354-766472396-501 METASPLOITABLE\nobody (Local User)  
S-1-5-21-1042354039-2475377354-766472396-512 METASPLOITABLE\Domain Admins (Domain Group)  
S-1-5-21-1042354039-2475377354-766472396-513 METASPLOITABLE\Domain Users (Domain Group)  
S-1-5-21-1042354039-2475377354-766472396-514 METASPLOITABLE\Domain Guests (Domain Group)  
S-1-5-21-1042354039-2475377354-766472396-1000 METASPLOITABLE\root (Local User)  
S-1-5-21-1042354039-2475377354-766472396-1001 METASPLOITABLE\root (Domain Group)  
S-1-5-21-1042354039-2475377354-766472396-1002 METASPLOITABLE\daemon (Local User)  
S-1-5-21-1042354039-2475377354-766472396-1003 METASPLOITABLE\daemon (Domain Group)  
S-1-5-21-1042354039-2475377354-766472396-1004 METASPLOITABLE\bin (Local User)  
S-1-5-21-1042354039-2475377354-766472396-1005 METASPLOITABLE\bin (Domain Group)  
S-1-5-21-1042354039-2475377354-766472396-1006 METASPLOITABLE\sys (Local User)  
S-1-5-21-1042354039-2475377354-766472396-1007 METASPLOITABLE\sys (Domain Group)  
S-1-5-21-1042354039-2475377354-766472396-1008 METASPLOITABLE\adm (Local User)  
S-1-5-21-1042354039-2475377354-766472396-1009 METASPLOITABLE\adm (Domain Group)  
S-1-5-21-1042354039-2475377354-766472396-1010 METASPLOITABLE\games (Local User)  
S-1-5-21-1042354039-2475377354-766472396-1011 METASPLOITABLE\tty (Domain Group)  
S-1-5-21-1042354039-2475377354-766472396-1012 METASPLOITABLE\man (Local User)  
S-1-5-21-1042354039-2475377354-766472396-1013 METASPLOITABLE\disk (Domain Group)  
S-1-5-21-1042354039-2475377354-766472396-1014 METASPLOITABLE\lp (Local User)  
S-1-5-21-1042354039-2475377354-766472396-1015 METASPLOITABLE\lp (Domain Group)  
S-1-5-21-1042354039-2475377354-766472396-1016 METASPLOITABLE\mail (Local User)  
S-1-5-21-1042354039-2475377354-766472396-1017 METASPLOITABLE\mail (Domain Group)  
S-1-5-21-1042354039-2475377354-766472396-1018 METASPLOITABLE\news (Local User)  
S-1-5-21-1042354039-2475377354-766472396-1019 METASPLOITABLE\news (Domain Group)  
S-1-5-21-1042354039-2475377354-766472396-1020 METASPLOITABLE\wuap (Local User)  
S-1-5-21-1042354039-2475377354-766472396-1021 METASPLOITABLE\wuap (Domain Group)  
S-1-5-21-1042354039-2475377354-766472396-1022 METASPLOITABLE\man (Domain Group)  
S-1-5-21-1042354039-2475377354-766472396-1023 METASPLOITABLE\proxy (Local User)  
S-1-5-21-1042354039-2475377354-766472396-1027 METASPLOITABLE\proxy (Domain Group)  
S-1-5-21-1042354039-2475377354-766472396-1031 METASPLOITABLE\modem (Domain Group)  
S-1-5-21-1042354039-2475377354-766472396-1041 METASPLOITABLE\dialout (Domain Group)  
S-1-5-21-1042354039-2475377354-766472396-1043 METASPLOITABLE\fax (Domain Group)  
S-1-5-21-1042354039-2475377354-766472396-1045 METASPLOITABLE\voice (Domain Group)  
S-1-5-21-1042354039-2475377354-766472396-1049 METASPLOITABLE\vcdrom (Domain Group)  
  
----- ( Getting printer info for 192.168.63.128 ) -----  
  
No printers returned.
```

Figure 11: enum4linux - Share Enumeration (tmp share publicly readable)

Table 11: SMB Shares Found

Share Name	Type	Comment	Access
print\$	Disk	Printer Drivers	DENIED
tmp	Disk	oh noes!	OK - Readable (Mapping: OK, Listing: OK)
opt	Disk	(empty)	DENIED
IPC\$	IPC	IPC Service (metasploitable server)	N/A
ADMIN\$	IPC	IPC Service (metasploitable server)	DENIED

The tmp share is publicly readable - temporary files, scripts, or sensitive data could be exposed or written to this share without authentication.

5.3 Users Found via Null Session RID Cycling (35 Accounts)

Figure 12: enum4linux - RID Cycling Output (35 accounts without authentication)

Table 12: Users Found via Null Session (35 Accounts)

Username	RID	Account Type	Significance
root	0x3e8	Local User	Superuser - highest privilege on the system
msfadmin	0xbb8	Local User	Primary admin - default credentials msfadmin:msfadmin
postgres	0x4c0	Local User	PostgreSQL DB administrator
mysql	0x4c2	Local User	MySQL service account - linked to exposed port 3306
tomcat55	0x4c4	Local User	Apache Tomcat service account
user	0xbba	Local User	Standard user (Name: just a user,111,,)
proftpd	0x4ca	Local User	ProFTPD service account - port 2121
distccd	0x4c6	Local User	Distributed compiler - potential CVE-2004-2687 vector
www-data	0x42a	Local User	Apache web server account
+ 26 more	various	Local/Domain	games, nobody, bind, proxy, syslog, news, bin, mail, dhcp, daemon, sshd, man, lp, gnats, libuuid, backup, telnetd, sys, klog, postfix, service, list, irc, ftp, sync, uucp

5.4 Password Policy

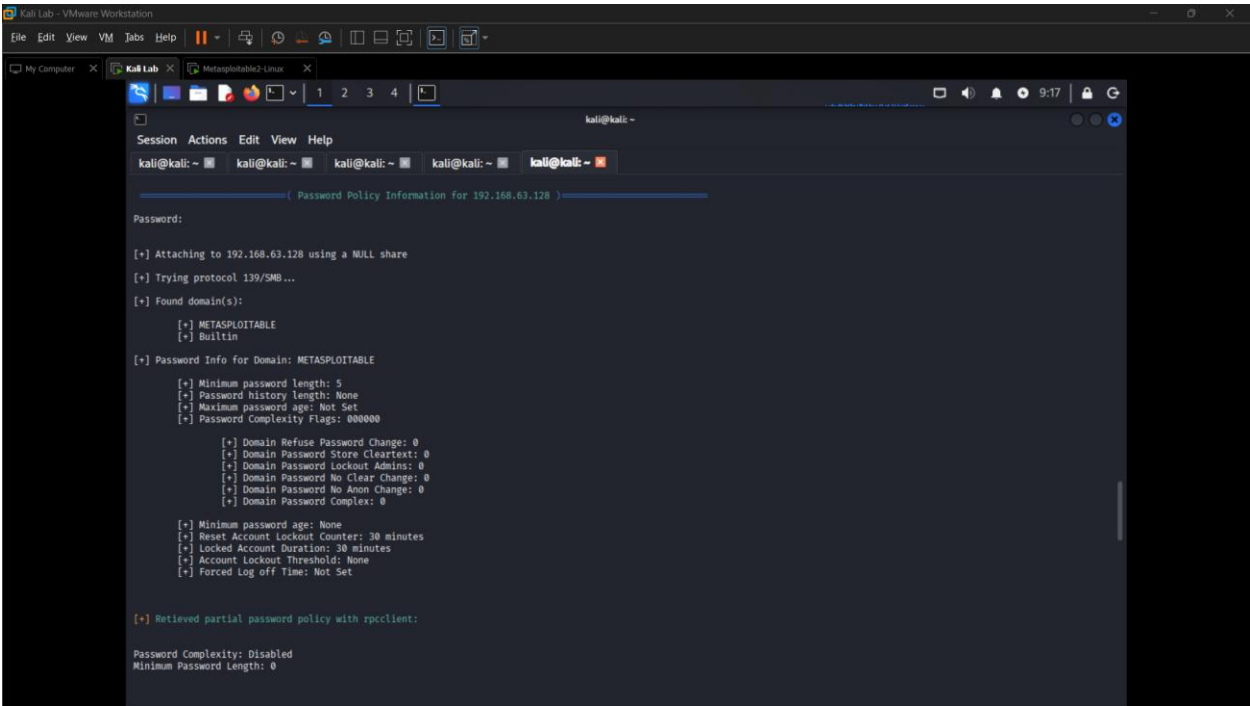


Figure 13: enum4linux - Password Policy (no lockout, no complexity)

Table 13: Password Policy

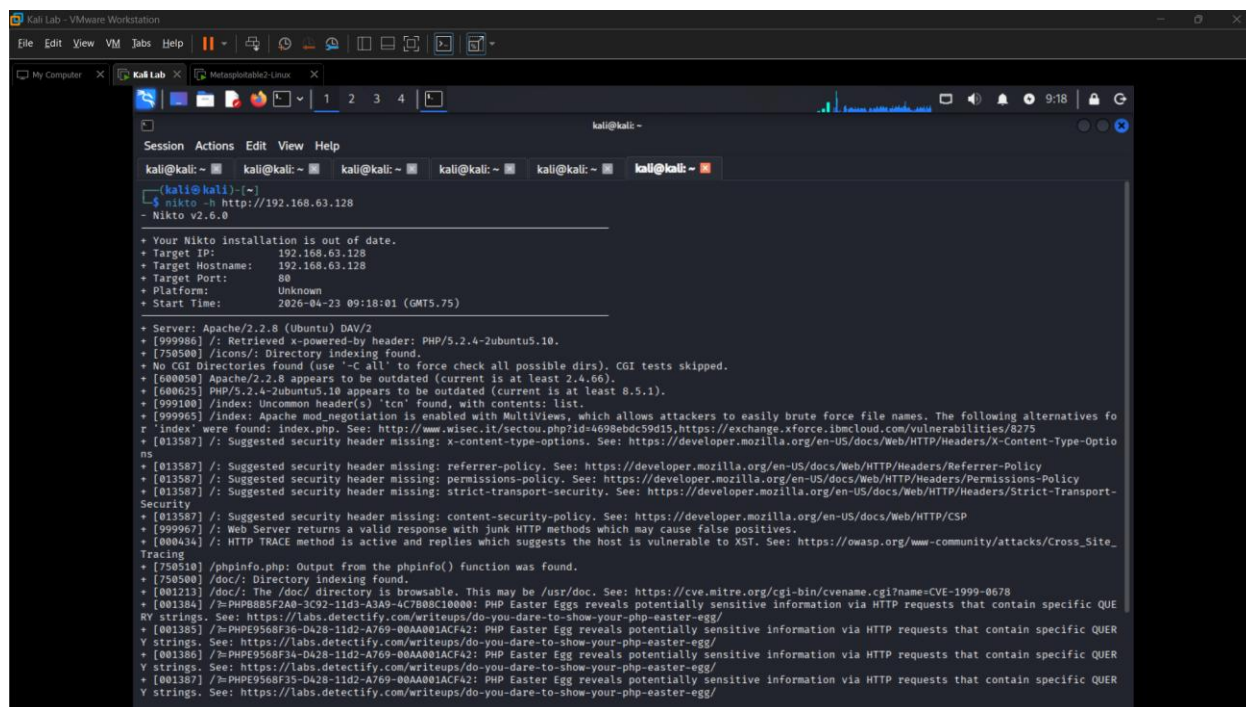
Policy Setting	Value
Minimum Password Length	5 characters (rpcclient reports: 0 - effectively no minimum)
Password Complexity	DISABLED - Password Complexity Flags: 000000
Password History	None - passwords can be reused immediately
Maximum Password Age	Not Set - passwords never expire
Account Lockout Threshold	None - unlimited brute-force attempts allowed
Lockout Duration	30 minutes (if threshold were set)

Risk Note: The complete absence of account lockout combined with no password complexity means all 35 enumerated accounts are fully susceptible to automated brute-force attacks.

6. Web Server Findings - Port 80

6.1 Niko Web Vulnerability Scan

Command: nikto -h http://192.168.63.128



```
kali@kali: ~  
$ nikto -h http://192.168.63.128  
- Nikto v2.6.0  
  
+ Your Nikto installation is out of date.  
+ Target IP: 192.168.63.128  
+ Target Hostname: 192.168.63.128  
+ Target Port: 80  
+ Platform: Unknown  
+ Start Time: 2026-04-23 09:18:01 (GMT5.75)  
  
+ Server: Apache/2.2.8 (Ubuntu) DAV/2  
+ [999986] /: Retrieved x-powered-by header: PHP/5.2.4-2ubuntu5.10.  
+ [750500] /icons/: Directory indexing found.  
+ No CGI Directories found (use '-C all' to force check all possible dirs), CGI tests skipped.  
+ [500050] Apache/2.2.8 appears to be outdated (current is at least 2.4.66).  
+ [600625] PHP/5.2.4-2ubuntu5.10 appears to be outdated (current is at least 8.5.1).  
+ [999100] /index: Uncommon header(s) 'tcn' found, with contents: list.  
+ [999965] /index: Apache mod_negotiation is enabled with MultiViews, which allows attackers to easily brute force file names. The following alternatives for 'index' were found: index.php. See: http://www.wisec.it/sectou.php?id=4698ebdc59d15, https://exchange.xforce.ibmcloud.com/vulnerabilities/8275  
+ [013587] /: Suggested security header missing: x-content-type-options. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Content-Type-Options  
+ [013587] /: Suggested security header missing: referrer-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Referrer-Policy  
+ [013587] /: Suggested security header missing: permissions-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Permissions-Policy  
+ [013587] /: Suggested security header missing: strict-transport-security. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Strict-Transport-Security  
+ [013587] /: Suggested security header missing: content-security-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/CSP  
+ [999967] /: Web Server returns a valid response with junk HTTP methods which may cause false positives.  
+ [000434] /: HTTP TRACE method is active and replies which suggests the host is vulnerable to XST. See: https://owasp.org/www-community/attacks/Cross_Site_Tracing  
+ [750510] /phpinfo.php: Output from the phpinfo() function was found.  
+ [750500] /doc/: Directory indexing found.  
+ [001213] /doc/: The /doc/ directory is browsable. This may be /usr/doc. See: https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-1999-0678  
+ [001384] />=PHE9568F34-0428-11d2-A769-00AA001ACF42: PHP Easter Eggs reveals potentially sensitive information via HTTP requests that contain specific QUERY strings. See: https://labs.detectify.com/writups/do-you-dare-to-show-your-php-easter-egg/  
+ [001385] />=PHE9568F36-0428-11d2-A769-00AA001ACF42: PHP Easter Egg reveals potentially sensitive information via HTTP requests that contain specific QUERY strings. See: https://labs.detectify.com/writups/do-you-dare-to-show-your-php-easter-egg/  
+ [001386] />=PHE9568F34-0428-11d2-A769-00AA001ACF42: PHP Easter Egg reveals potentially sensitive information via HTTP requests that contain specific QUERY strings. See: https://labs.detectify.com/writups/do-you-dare-to-show-your-php-easter-egg/  
+ [001387] />=PHE9568F35-0428-11d2-A769-00AA001ACF42: PHP Easter Egg reveals potentially sensitive information via HTTP requests that contain specific QUERY strings. See: https://labs.detectify.com/writups/do-you-dare-to-show-your-php-easter-egg/
```

Figure 14: Nikto - Full Web Vulnerability Scan Output

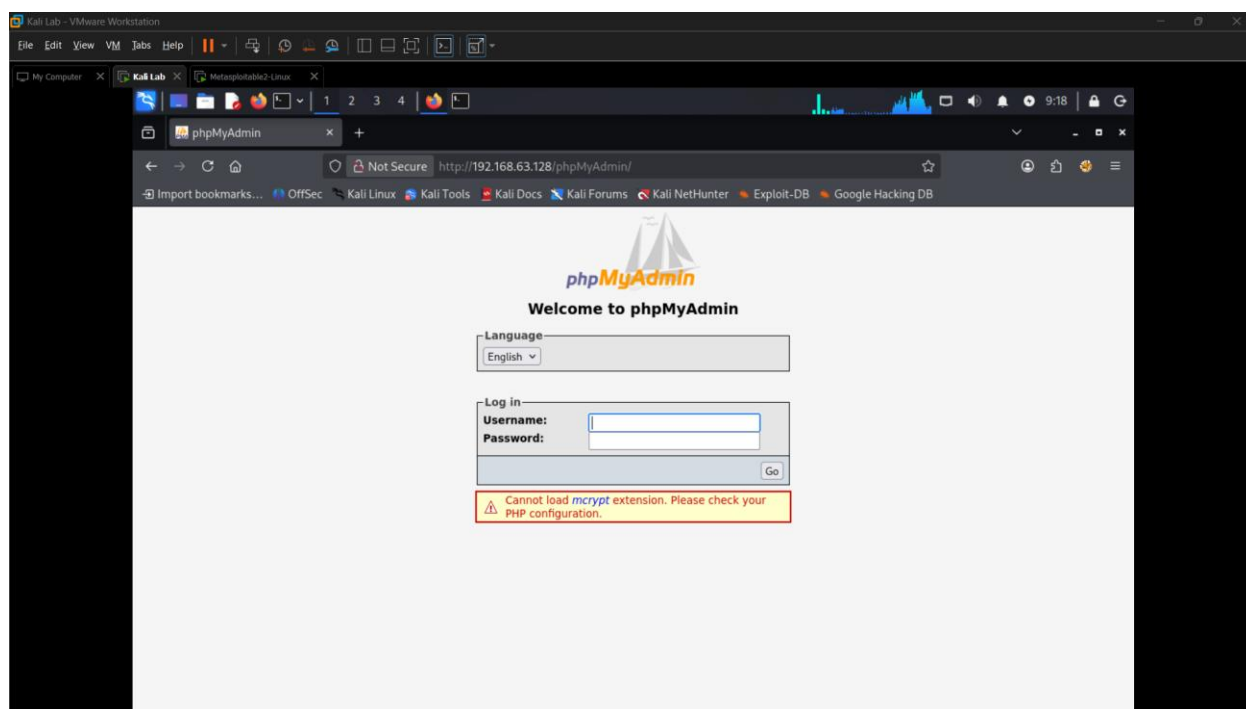


Figure 15: phpMyAdmin - Publicly Accessible Database Admin Panel

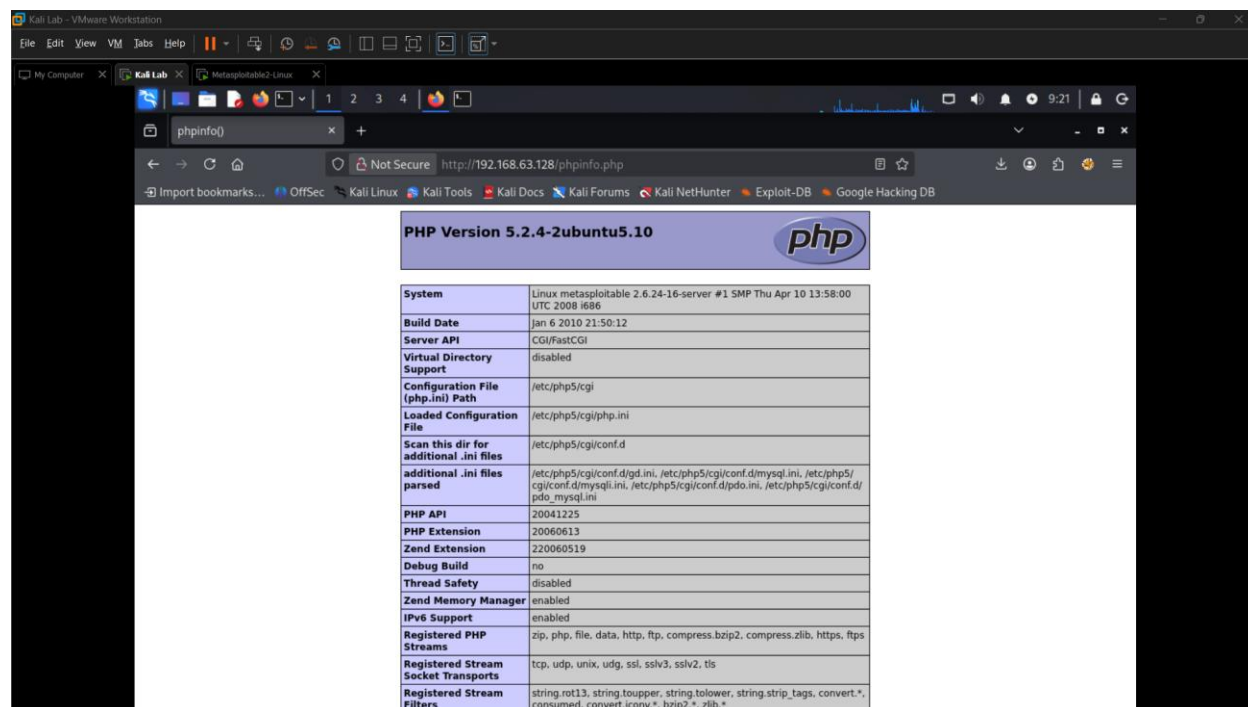


Figure 16: phpinfo.php - Full PHP Configuration Exposure

Table 14: Nikto Web Vulnerability Scan Results

#	Finding	Risk	Reference
1	Apache/2.2.8 is critically outdated - multiple known CVEs including RCE. Nmap banner confirmed: Apache/2.2.8 (Ubuntu) DAV/2. Current version is 2.4.66.	HIGH	[600050]
2	PHP/5.2.4-2ubuntu5.10 is critically outdated - RCE and information disclosure. Exposed via x-powered-by response header. Current is PHP 8.5.1.	HIGH	[600625]
3	HTTP TRACE method is active - server is vulnerable to Cross-Site Tracing (XST) enabling session cookie theft via malicious JavaScript.	HIGH	[000434]
4	/phpMyAdmin/ exposed (HTTP 301) - database admin panel publicly accessible. Direct path to full MySQL database compromise. Changelog files also publicly readable.	HIGH	[001795/96]
5	/phpinfo.php exposed - reveals server internal paths, PHP version, all loaded modules, environment variables, and configuration settings. CWE-552.	HIGH	[002989]
6	/icons/ directory indexing enabled - full directory listing publicly accessible, exposing internal file structure.	MEDIUM	[750500]
7	/doc/ directory browsable - may expose system documentation at /usr/doc (CVE-1999-0678).	MEDIUM	[001213]
8	PHP Easter Eggs enabled - four Easter Egg URLs return sensitive version and system information, confirming exact PHP build.	MEDIUM	[001384-87]
9	Five security headers missing: x-content-type-options, referrer-policy, strict-transport-security, permissions-policy, content-security-policy.	MEDIUM	[013587]

#	Finding	Risk	Reference
10	Apache mod_negotiation with MultiViews enabled - allows brute-force of hidden filenames. inode leakage via ETags (CVE-2003-1418).	LOW	[999965]

6.2 Gobuster Directory Enumeration

```
Command: gobuster dir -u http://192.168.63.128 -w
/usr/share/wordlists/dirb/common.txt
```

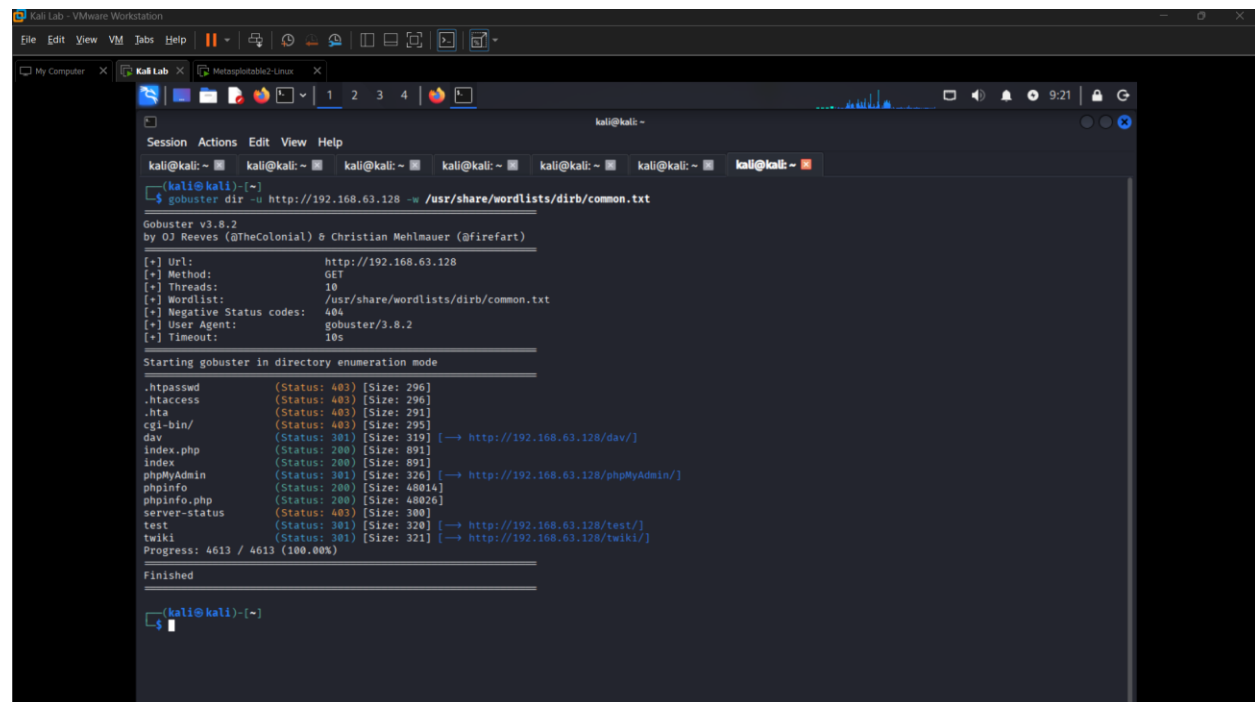


Figure 17: Gobuster - Directory Enumeration Output

Table 15: Gobuster Directory Enumeration Results

Discovered Path	Status Code	Risk & Notes
/phpMyAdmin	301 Redirect	HIGH - Database admin panel publicly exposed. Direct path to full MySQL compromise.
/phpinfo.php	200 OK	HIGH - Full PHP and server configuration exposed including internal paths.
/phpinfo	200 OK	HIGH - Same PHP info page accessible without .php extension (mod_negotiation enabled).
/dav	301 Redirect	MEDIUM - WebDAV enabled. May allow unauthenticated file upload to server.
/test	301 Redirect	MEDIUM - Test directory publicly accessible. May contain sensitive test files.
/twiki	301 Redirect	MEDIUM - TWiki wiki installation found. Older versions have known vulnerabilities.
/index.php	200 OK	LOW - Main application index page (Size: 891 bytes).

Discovered Path	Status Code	Risk & Notes
/.htaccess, .htpasswd	403 Forbidden	INFO - Files exist but access denied. Confirms Apache config files are present.
/cgi-bin/	403 Forbidden	INFO - CGI directory present. Could be enabled for CGI-based attacks.
/server-status	403 Forbidden	INFO - Apache server-status page present. Should not exist on production servers.

7. Recommendations

The following three actions must be taken immediately to reduce the critical attack surface identified during this assessment. Prioritised by severity and ease of exploitation.

Table 16: Prioritised Recommendations

S.N.	Action Required
1	IMMEDIATE: Uninstall vsftpd 2.3.4 and Disable Telnet vsftpd 2.3.4 contains a known remote root backdoor (CVE-2011-2523, CVSS 10.0). Run the following commands: <pre>sudo apt-get remove vsftpd && sudo service telnetd stop && sudo update-rc.d telnetd disable</pre> Replace FTP with SFTP via OpenSSH. If FTP is required, upgrade to vsftpd 3.0.5 or later. All remote access must use SSH with key-based authentication only.
2	URGENT: Upgrade Samba and Disable SMB Null Sessions Samba 3.0.20 is vulnerable to unauthenticated RCE (CVE-2007-2447, CVSS 9.3). Upgrade Samba, then in /etc/samba/smb.conf add: <pre>restrict anonymous = 2 map to guest = Never server signing = mandatory</pre> Block ports 139 and 445: <code>sudo ufw deny 139 && sudo ufw deny 445</code>. This prevents the null session that exposed 35 user accounts.
3	HIGH: Secure MySQL and Remediate Web Exposure Set a strong MySQL root password and bind to localhost only: <pre>mysqladmin -u root password 'StrongP@ss!123' then add bind-address=127.0.0.1 to /etc/mysql/my.cnf</pre> Remove /phpinfo.php, restrict /phpMyAdmin to authorised IPs, upgrade Apache to 2.4.x, upgrade PHP to 8.x, disable HTTP TRACE, and add all missing security headers.

Report prepared by Sulav Adhikari | Hack Start Pro VAPT Internship | Arrownex Pvt. Ltd. | April 2026

CONFIDENTIAL - FOR TRAINING PURPOSES ONLY